

AWS Security Architecture & Best Practices

A comprehensive guide to securing cloud workloads on AWS for modern enterprise environments

Minh Huỳnh
Solution Architect - TechX

Information Technology & Cybersecurity



PARTNER
Premier Tier
Services

Agenda

01 Introduction to AWS Security

02 Identity & Access Management (IAM)

03 Network Security (VPC, WAF, Shield)

04 Data Protection & Encryption

05 Logging, Monitoring & Auditing

06 Threat Detection & Security Monitoring

07 Container & Kubernetes Security

08 DevSecOps & CI/CD Security

09 Multi-Account Architecture

10 Incident Response on AWS

01

Introduction to AWS Security

Why cloud security matters more than ever

Why Cloud Security Matters

The stakes have never been higher

\$4.88M

Average cost of a data breach (IBM 2024)

39%

Breaches involve stolen credentials

82%

Breaches involve cloud-stored data

277

Average days to identify a breach

<https://wp.table.media/wp-content/uploads/2024/07/30132828/Cost-of-a-Data-Breach-Report-2024.pdf>

Security Challenges in Cloud Environments

Cloud introduces unique security complexities



Shared Responsibility

Misunderstanding what AWS secures vs. what you secure



Identity Sprawl

Thousands of IAM users, roles, and permissions to manage



Visibility Gap

Hard to monitor all resources across accounts and regions



Misconfiguration

#1 cause of cloud breaches — public S3 buckets, open ports



Dynamic Infrastructure

Resources spin up/down; static security tools fail



Rapid Change

DevOps speed vs. security review bottlenecks

AWS Security Services



Identity and access management



AWS IAM
Identity Center



Amazon Cognito



AWS RAM



IAM



Network and app protection



AWS Firewall
Manager



AWS Shield



AWS Network Firewall



AWS WAF



Data protection



Amazon Macie



AWS CloudHSM



AWS Private
Certificate Authority



AWS KMS



AWS Certificate
Manager



AWS Secrets
Manager



Detection and response



AWS Config



AWS CloudTrail



Amazon Inspector



AWS Security Hub



Amazon Detective



Amazon GuardDuty



Amazon Security Lake



Governance and compliance



AWS Organizations



AWS Control Tower



AWS Artifact

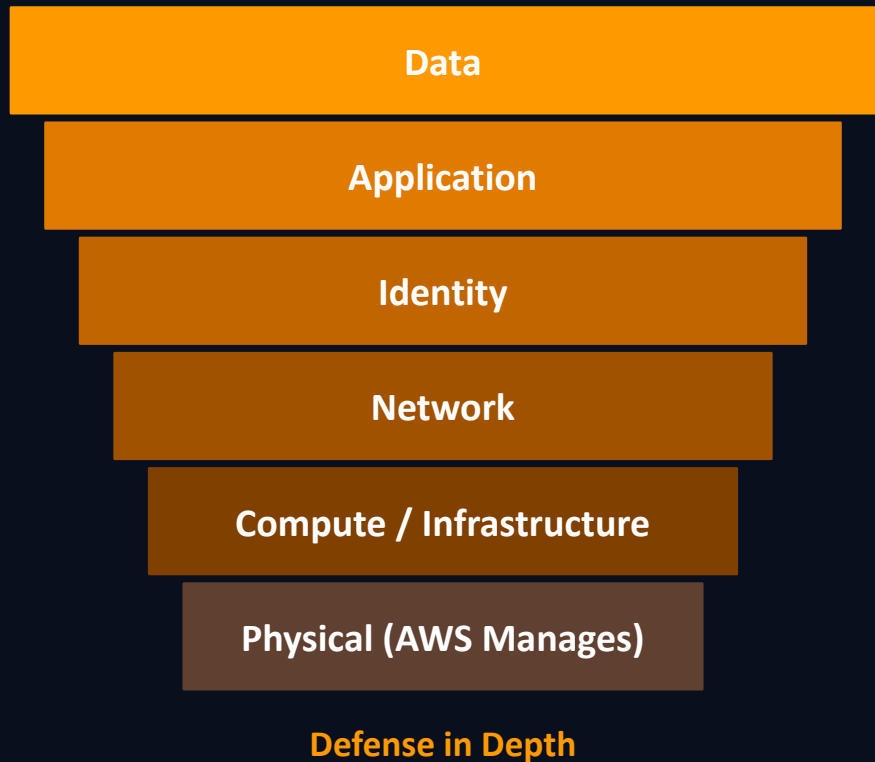


AWS Audit Manager



AWS Security Overview

50+ security, compliance, and governance services



AWS Security Principles



Zero Trust Architecture — Never trust, always verify



Continuous Monitoring — Real-time threat detection



Encryption Everywhere — At rest, in transit, in use



Compliance Automation — CIS, NIST, PCI-DSS, SOC2

AWS Well-Architected — Security Pillar

7 design principles for secure cloud workloads

01

Implement Strong Identity

Least privilege, MFA, no long-lived credentials

02

Enable Traceability

Monitor, alert, audit all actions in real time

03

Apply Security at All Layers

VPC, subnet, OS, application — defense in depth

04

Automate Security Practices

IaC security checks, automated remediation

05

Protect Data in Transit & at Rest

Encryption, tokenization, classification

06

Keep People Away from Data

Automate access, reduce human touch on sensitive data

07

Prepare for Security Events

Incident response runbooks, game days

02

Identity & Access Management

Controlling who can do what on AWS

IAM Fundamentals

AWS Identity and Access Management — Who can do what to which resource



Users

Individual identities for people or services with long-term credentials



Groups

Collection of users that share the same permissions policies



Roles

Temporary credentials — assumed by services, apps, or federated users



Policies

JSON documents defining Allow/Deny for specific AWS actions on resources

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "s3:GetObject",
      "s3:PutObject"
    ],
    "Resource":
      "arn:aws:s3:::my-bucket/*",
    "Condition": {
      "Bool": {
        "aws:MultiFactorAuth": "true"
      }
    }
  }]
}
```

Sample IAM Policy



Least Privilege Principle

Grant ONLY the permissions needed to perform a task — nothing more.

Use IAM Access Analyzer to detect unused permissions and refine policies automatically.

Multi-Factor Authentication & Least Privilege

Two of the most impactful IAM security controls



Multi-Factor Authentication (MFA)

- Requires something you KNOW + something you HAVE
- Supported MFA types in AWS:
- Virtual MFA (Google Authenticator, Authy)
- Hardware TOTP tokens (Gemalto)
- FIDO2 Security Keys (YubiKey)
- Enable MFA on root account — ALWAYS
- Enforce MFA via IAM Condition Keys
- Use SCPs to require MFA org-wide



Least Privilege Access

- Start with zero permissions, add only what's needed
- Use managed policies vs inline policies
- Tools to help:
- IAM Access Analyzer
- AWS CloudTrail — track used permissions
- IAM Last Access Report
- Rotate access keys every 90 days max
- Prefer IAM Roles over long-lived keys



The root account should NEVER be used for day-to-day tasks. Lock it down immediately after account creation.

Multi-Factor Authentication & Least Privilege



Multi-factor Authentication

Please enter an MFA code to complete sign-in.

MFA Code:

Submit

[Cancel](#)

Set up device

Set up your authenticator app

A virtual MFA device is an application running on your device that you can configure by scanning a QR code.

1

Install a compatible application such as Google Authenticator, Duo Mobile, or Authy app on your mobile device or computer.
[See a list of compatible applications](#)

2



Open your authenticator app, chose **Show QR code** on this page, then use the app to scan the code.
Alternatively, you can type a secret key. [Show secret key](#)

3

Fill in two consecutive codes from your MFA device.

MFA code 1

MFA code 2

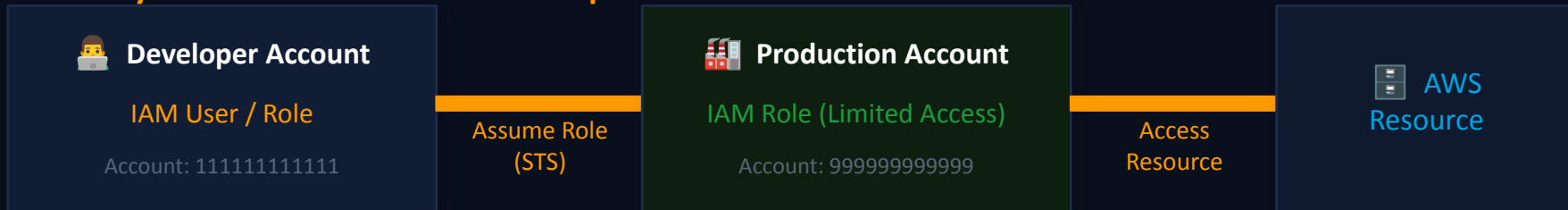
Cancel

Previous

Add MFA

Cross-Account Access & IAM Identity Center

Securely access resources across multiple AWS accounts



Trust Policy (on Prod Role)

```
{
  "Principal": {
    "AWS": "arn:aws:iam::111111:user/Dev"
  },
  "Action": "sts:AssumeRole",
  "Condition": { "Bool": {
    "aws:MultiFactorAuthPresent": "true"
  }}
}
```



IAM Identity Center (SSO)

- Single sign-on for all AWS accounts
- Integrates with Active Directory, Okta, Azure AD
- Centrally assign permission sets
- Temporary credentials — no static keys

Advanced IAM Concepts:

Permission

Boundaries:

Max permissions an entity can have

Resource-Based

Policies:

Attached to resources (S3, KMS, SQS)

Session Policies:

Passed during role assumption via STS

IAM — Key Takeaways

What you should remember from this section



Never use the root account for daily tasks — lock it down with MFA immediately



Use IAM Roles (temporary credentials) instead of IAM Users with access keys wherever possible



Enforce Least Privilege — start with minimum permissions and expand only when justified



Enable MFA on all human users — make it a mandatory organizational control via SCP



Use IAM Identity Center for centralized SSO across all accounts in your organization



Regularly audit permissions with IAM Access Analyzer and Last Access Reports

03

Network Security

VPC, WAF, Shield & Network Firewall

Amazon VPC & Network Architecture

Your private, isolated section of the AWS cloud

AWS Region

VPC: 10.0.0.0/16

Public Subnet

10.0.1.0/24

NAT Gateway
Internet GW

Private Subnet

10.0.2.0/24

EC2 / RDS
App Servers

Security Group (Stateful)

Network ACL (Stateless)

Route Tables control traffic flow

VPC Endpoints keep traffic within AWS

Security Groups

Stateful instance-level firewall. Allow rules only. Applied to ENI.

Network ACLs

Stateless subnet-level firewall. Allow AND Deny rules. Numbered order.

VPC Endpoints

Private connection to AWS services without internet. Interface or Gateway type.

AWS PrivateLink

Expose services privately across VPCs and accounts without VPC peering.

AWS WAF, Shield & Network Firewall

Multi-layer protection against network-level attacks



AWS WAF — OWASP Top 10 Protection

- ✓ SQL Injection → WAF inspects query strings
- ✓ XSS Attacks → Block malicious scripts in input
- ✓ Rate Limiting → Block DDoS / credential stuffing

AWS Shield — DDoS Protection

- ✓ Shield Standard: free, automatic for all AWS
- ✓ Shield Advanced: \$3k/month, 24/7 DRT team
- ✓ Protects: EC2, ALB, CloudFront, Route 53

AWS Network Firewall — Stateful L3/L4/L7 Protection

Stateful Rules:

Domain filtering, Suricata-compatible IPS rules

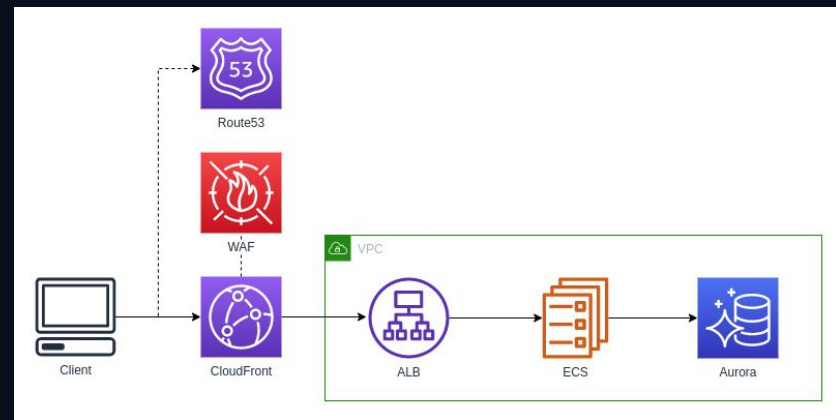
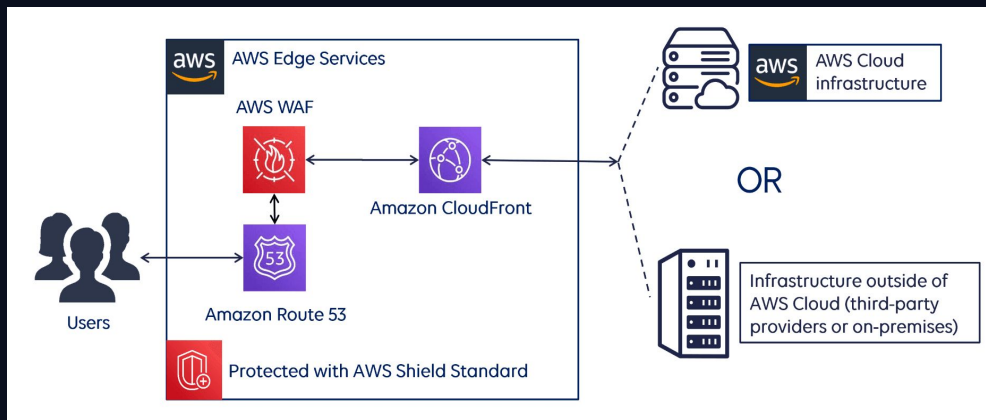
Stateless Rules:

Packet header inspection, fast-path rules

Centralized:

Deploy in shared services VPC, protect all workloads

AWS WAF, Amazon Shield & AWS CloudFront



Network Security Best Practices

A layered approach to network defense

Never Expose Databases Directly

01

Databases must live in private subnets. Access only through application layer or VPN.

Use Security Groups as Firewalls

02

Default deny all inbound. Allow only specific ports from specific sources (not 0.0.0.0/0).

Enable VPC Flow Logs

03

Log all accepted and rejected traffic for forensics, anomaly detection, and compliance.

Use VPC Endpoints

04

S3, DynamoDB, and 100+ services reachable privately — no internet gateway required.

Segment with Multiple VPCs

05

Separate dev, staging, and production. Use Transit Gateway for controlled inter-VPC routing.

Enable GuardDuty Network Findings

06

Detect unusual DNS requests, cryptocurrency mining, C2 traffic from your VPCs.

Network Security — Key Takeaways

What you should remember from this section



Design VPCs with public/private subnet separation — databases and internal services NEVER in public subnets



Security Groups are your primary firewall — default deny all inbound, allow only specific ports from known sources



Enable VPC Flow Logs — essential for incident investigation and anomaly detection (store in S3, query with Athena)



Use VPC Endpoints to keep traffic to AWS services (S3, DynamoDB, ECR) private and off the internet



Deploy WAF in front of any public-facing application — protect against OWASP Top 10 attacks



AWS Shield Standard is free and always on — upgrade to Advanced for DDoS response team and cost protection

04

Data Protection & Encryption

Protecting data at every stage of its lifecycle

Data Protection & Encryption

Protecting data at every stage of its lifecycle



Encryption At Rest

Data stored in databases, file systems, and object storage

- ✓ AWS KMS
- ✓ S3 Server-Side Encryption
- ✓ EBS Volume Encryption
- ✓ RDS Encryption



Encryption In Transit

Data moving across networks between services or to clients

- ✓ TLS 1.2/1.3
- ✓ AWS Certificate Manager
- ✓ HTTPS Everywhere
- ✓ VPN / Direct Connect



Encryption In Use

Data being actively processed by compute resources

- ✓ AWS Nitro Enclaves
- ✓ Confidential Computing
- ✓ Tokenization
- ✓ Homomorphic Encryption

AWS KMS & Secrets Manager

Centralized key management and secrets lifecycle

AWS Key Management Service (KMS)

- Fully managed encryption key service
- FIPS 140-2 Level 2 validated hardware security modules
- Key Types:
 - AWS Managed Keys (free, auto-rotated)
 - Customer Managed Keys (CMK) — full control
 - AWS Owned Keys (shared, no visibility)
- Automatic annual key rotation (or on-demand)
- Integrated with 100+ AWS services

AWS Secrets Manager

- Store database credentials, API keys, tokens
- Automatic secret rotation with Lambda
- Integrates natively with RDS, Redshift, DocumentDB
- Fine-grained access via IAM resource policies
- Cross-account access supported
- Audit access with CloudTrail

Architecture: App → Secrets Manager → Database (No Hardcoded Passwords)



Application



Secrets
Manager
API Call

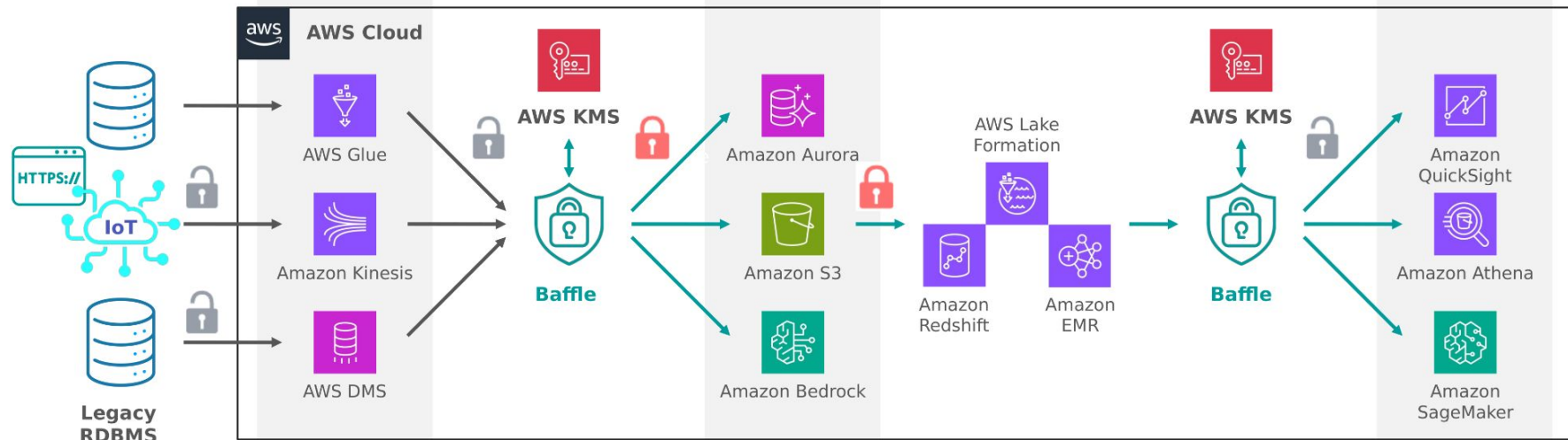


Temp
Credential
Returned



Database
Connected

AWS KMS & Database and Data Analyze



Amazon S3 Security

Securing the world's largest object storage service



Block Public Access

Account-level setting to prevent any public bucket/object ACLs. Enable this ALWAYS.



Bucket Policies

JSON resource-based policies controlling who can access the bucket and under what conditions.



SSE-S3 / SSE-KMS

Server-side encryption with S3-managed keys or customer-managed KMS keys.



S3 Access Logs

Log every request made to the bucket for audit and compliance purposes.



Object Lock (WORM)

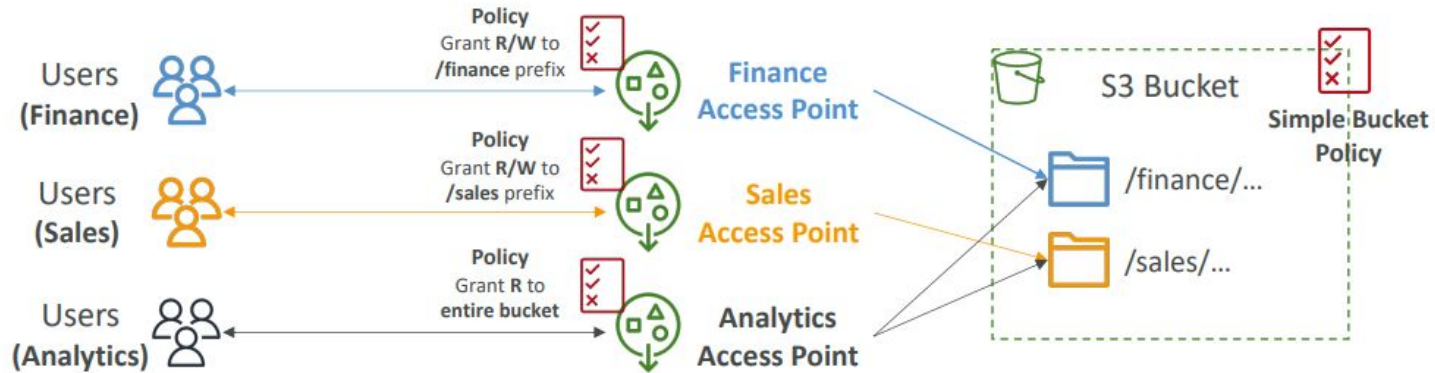
Prevent object deletion for a retention period. Critical for compliance (SEC, CFTC).



Amazon Macie

ML-powered service to discover and protect sensitive data (PII, financial data) in S3.

Amazon S3 Security - Multiple Team



Data Protection — Key Takeaways

Encryption, key management, and secrets done right



Use AWS KMS for all encryption key management — never store encryption keys alongside encrypted data



Use Secrets Manager for all credentials (DB passwords, API keys) — auto-rotation eliminates stale credentials



Enable S3 Block Public Access at the account level — prevents any bucket from being accidentally made public



Enable key rotation in KMS (annual minimum) — helps contain impact if a key is compromised



Use S3 Object Lock (WORM) for compliance data — immutable storage protects against ransomware



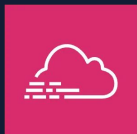
Deploy Amazon Macie to continuously discover PII and sensitive data across your S3 buckets

05

Logging, Monitoring & Auditing

Visibility is the foundation of security

Logging, Monitoring & Auditing



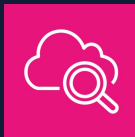
AWS CloudTrail

What: Records all AWS API calls — who did what, when, from where

Why: Non-repudiation, compliance, incident forensics

Example: Detect: 'Who deleted the S3 bucket?'

- All regions, all services
- S3 storage + optional CloudWatch Logs
- Data events (object-level S3, Lambda)
- Insights for anomalous activity



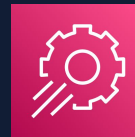
Amazon CloudWatch

What: Collects metrics, logs, events from AWS services and applications

Why: Real-time visibility into resource health and performance

Example: Alert: CPU spike on EC2, unusual API error rates

- Metric alarms → SNS → PagerDuty
- Log Insights for querying logs
- Dashboard for security metrics
- Anomaly detection with ML



AWS Config

What: Tracks configuration changes to AWS resources over time

Why: Configuration compliance and drift detection

Example: Rule: 'S3 buckets must not be public'

- 140+ managed rules
- Custom rules via Lambda
- Auto-remediation support
- Compliance score tracking

AWS Audit Manager & Compliance Automation

Continuously assess controls against compliance frameworks



AWS Audit Manager

Continuously audit AWS usage to simplify how you assess risk and compliance with regulations and industry standards. Auto-collects evidence.

CIS AWS Foundations Benchmark

Baseline security hardening for AWS accounts — 50+ controls

NIST 800-53

Federal information security controls
— used by US government contractors

PCI DSS

Payment card industry standard — required for processing credit cards

SOC 2

Service organization trust criteria — required by enterprise customers

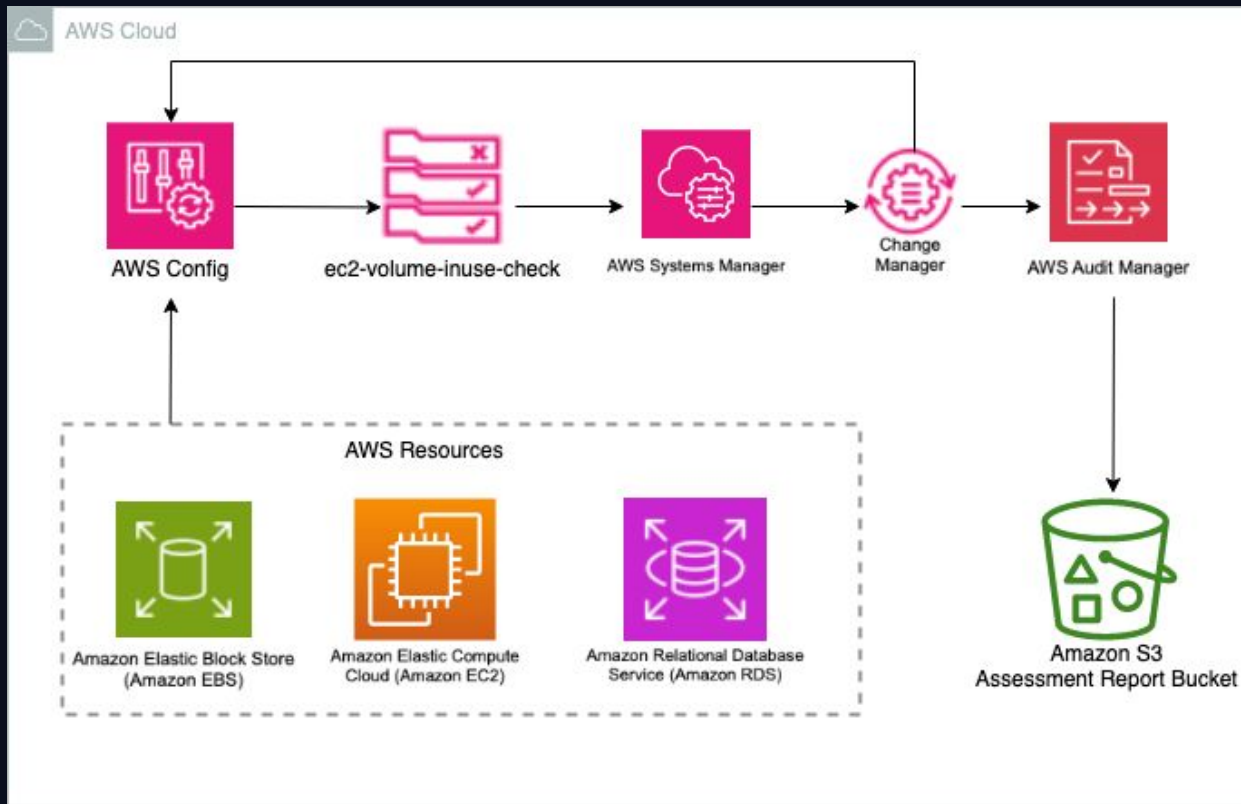
ISO 27001

International information security management standard

HIPAA

US healthcare data privacy and security requirements

Automated Evidence Collection with AWS Audit Manager



Logging & Monitoring — Key Takeaways

Visibility is the foundation of security



Enable CloudTrail in ALL regions with multi-region trail — attacks don't stay in one region



CloudWatch Metrics + Alarms — set thresholds for security events (failed logins, API errors, IAM changes)



AWS Config Rules — continuously evaluate compliance; use auto-remediation for critical violations



Store CloudTrail logs in a dedicated Log Archive account with Object Lock — immutable evidence



Use CloudWatch Logs Insights for fast log queries — essential during active incident investigation



Audit Manager continuously collects evidence against compliance frameworks — reduces audit prep time by 90%

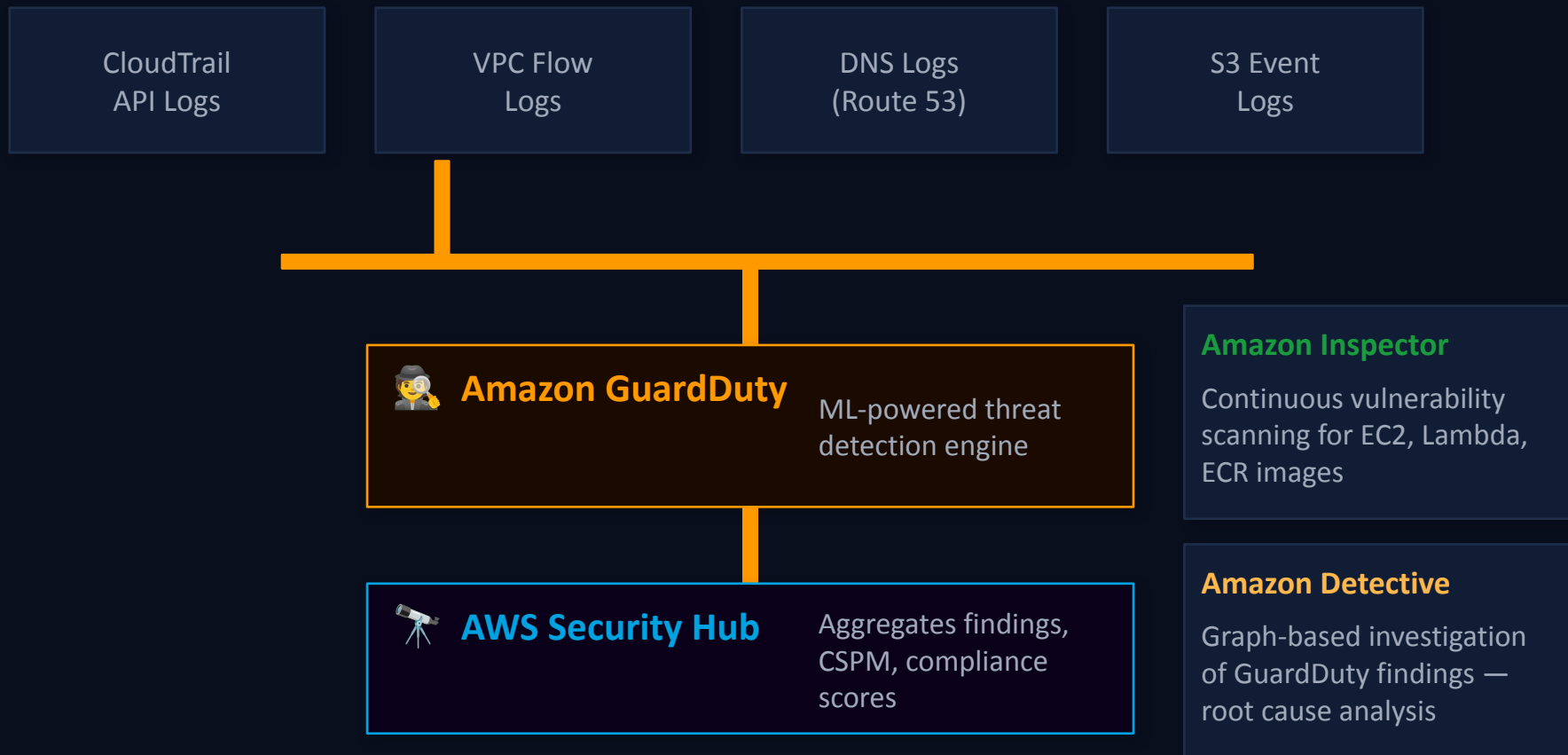
06

Threat Detection & Security Monitoring

Finding threats before they find you

Threat Detection & Security Monitoring

AWS native services for identifying and responding to threats



GuardDuty — Real Attack Scenarios

What GuardDuty detects and how it alerts your team



Credential Compromise

HIGH

Finding: `UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration`

EC2 instance credentials used from an external IP — likely stolen via SSRF or metadata attack

Action: Revoke credentials, isolate instance, investigate metadata access logs



Cryptocurrency Mining

HIGH

Finding: `CryptoCurrency:EC2/BitcoinTool.B!DNS`

EC2 instance making DNS queries to known cryptocurrency mining pool domains

Action: Isolate instance, check for unauthorized process, review IAM permissions used



Reconnaissance / Port Scan

MEDIUM

Finding: `Recon:EC2/PortProbeUnprotectedPort`

EC2 instance being probed by a known scanner — potential pre-attack reconnaissance

Action: Review Security Group rules, update WAF rules, enable Shield Advanced

AWS Security Hub & Amazon Inspector

Centralized security posture and vulnerability management



AWS Security Hub

The single pane of glass for AWS security findings

Aggregates findings from:

- ✓ GuardDuty
- ✓ Inspector
- ✓ Macie
- ✓ IAM Access Analyzer
- ✓ Firewall Manager
- ✓ CIS AWS Foundations Benchmark
- ✓ AWS Foundational Security Best Practices
- ✓ PCI DSS, NIST 800-53



Amazon Inspector

Automated vulnerability management — continuous scanning

EC2 Instances

OS and package CVE scanning via SSM agent

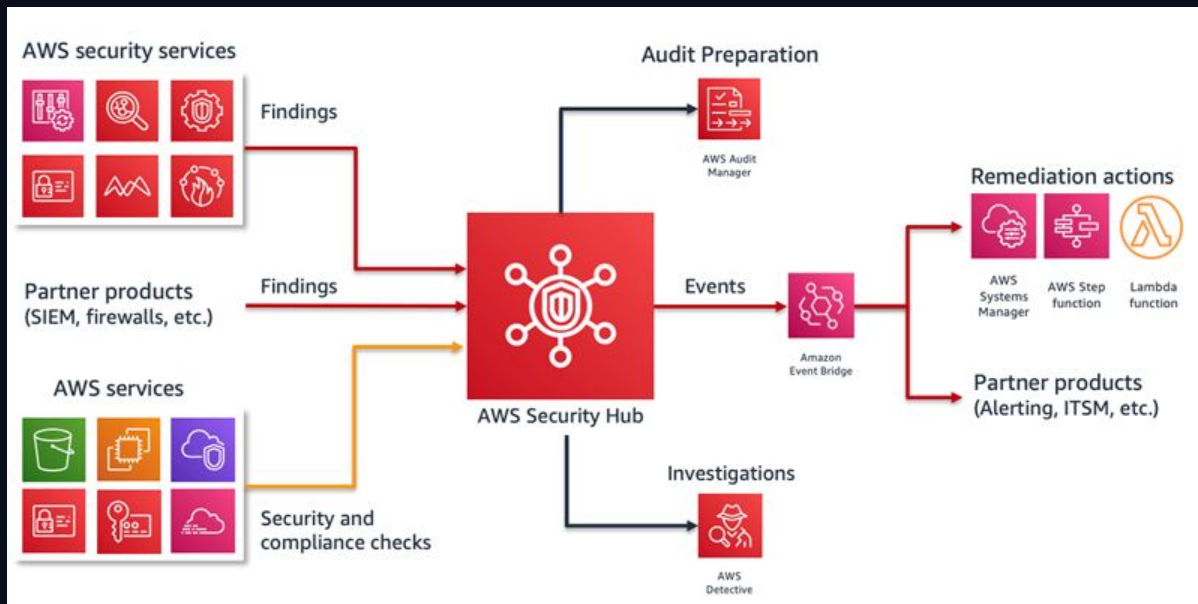
Lambda Functions

Package dependencies scanned for vulnerabilities

ECR Container Images

Scan on push or continuously in registry

AWS Security Hub Integration Services



AWS Security Hub Dashboard

Security Hub

Summary

Security Hub

Dashboard

Summary

Exposure

Threats

Vulnerabilities

Posture management

Sensitive data

Inventory

Findings

Resources

Management

Integrations

Automations

Settings

General

Detection engines

GuardDuty

Inspector

Security Hub CSPM

Macie

Region: us-east-1 (home Region)

Reset to default layout

+ Add widget

+ Create Custom Widget

Save filter sets

Choose a filter set

Q Add filter

Threat summary

A threat finding is an event with the potential to adversely impact operations, assets, or individuals. Top severity detections are listed below.

Critical

14

High

0

Medium

32

Low

30

Findings

Severity

Potential credential compromise of AssumedRole/ indicated by a sequence of actions.

Critical

Potential credential compromise of AssumedRole/ indicated by a sequence of actions.

Critical

View all threats

Exposure summary

An exposure finding is a correlation of multiple security findings, resource relationships and configurations. The exposure findings with the greatest severity and most findings are listed below.

Critical

10

High

10

Medium

3

Low

62

Exposure

Severity

Count

Potential Unauthorized Access: IAM user has administrative access policy, weak password policies, and MFA disabled

Critical

5

More

Potential Credential Stealing: Internet reachable EC2 instance with administrative instance profile has network-exploitable software vulnerabilities with a high likelihood of

Critical

4

View all exposure findings

Resource summary

Security coverage

SIP deliverables – Weighted maturity model

TOTAL SECURITY MECHANISMS ACROSS DIFFERENT SECURITY PILLAR & SEVERITY								How Maturity Score is calculated? Weighted Maturity Score Logic = Weighted average of mechanisms (Yes/Yes+No+In Progress) multiplied by total weightage of the severity divided by arithmetic mean of total weightage across each mechanisms and severities. Weight: Critical 100, High 75, Medium 50, Low 25					
Security Pillars & Severity	CRITICAL	HIGH	MEDIUM	LOW	Total Mechanisms	Pillar Weightage %							
IAM	7	12	18	7	44	20%							
Detection	6	8	22	9	45	20%							
Infrastructure Protection	7	17	23	10	57	25%							
Data Protection	9	13	29	16	67	30%							
Incident Response	1	4	5	1	11	5%							
Total Mechanisms	30	54	97	43	224	100%							
Severity Weightage %	13%	24%	43%	19%	100%								
CUSTOMER'S RESPONSE, MECHANISMS & MATURITY ACROSS DIFFERENT SECURITY PILLAR & SEVERITY													
Severity & Security Pillars	CRITICAL		HIGH		MEDIUM		LOW		Customer's Mechanisms		Process in place	Risks Identified	
Customer's Response	Y	N	Y	N	Y	N	Y	N	Y	N			
IAM	6	1	10	2	11	7	6	1	33	11	80%	20%	
Detection	2	4	1	7	12	10	3	6	18	27	31%	69%	
Infrastructure Protection	5	2	9	8	12	11	7	3	33	24	62%	38%	
Data Protection	7	2	9	4	11	18	8	8	35	32	64%	36%	
IR & Automation	1	0	0	4	2	3	0	1	3	8	48%	52%	
Customer's Mechanisms	21	9	29	25	48	49	24	19	122	102			
Maturity Score											57%	43%	

How Maturity Score is calculated?

Weighted Maturity Score Logic = Weighted average of mechanisms (Yes/Yes+No+In Progress) **multiplied** by total weightage of the severity **divided** by arithmetic mean of total weightage across each mechanisms and severities.

Weight: **Critical** 100, **High** 75, **Medium** 50, **Low** 25

AWS Security Hub Integration Jira Management

 Jira

Your work ▾

Projects ▾

Filters ▾

Dashboards ▾

People ▾

Apps ▾

Create



 AWS Security Alerts
Software project

 Back to project

Filters

All issues

My open issues

Reported by me

Open issues

Done issues

Viewed recently

Resolved recently

Updated recently

View all filters

You're in a company-managed project
[Learn more](#)

Projects / AWS Security Alerts

Issues

Search issues

Project: AWS Security Alerts ▾

Type ▾

Status ▾

Assignee ▾

More +

Save filter

Share ▾

Export issues ▾

Go to advanced search

LIST VIEW ▮

DETAIL VIEW ▮

...

BASIC

JQL

Type	Key	Summary	Assignee	Reporter	P	Status	Resolution
	ASA-863	2.1.5.2 S3 Block Public Access setting should be enabled at the bucket-level	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-862	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-861	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-860	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-859	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-858	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-857	KMS.2 IAM principals should not have IAM inline policies that allow decryption actions on all KMS keys	 Alex	 AWS Service Man...		TO DO ▾	Unresolved
	ASA-856	IAM.2 IAM users should not have IAM policies attached	 Unassigned	 AWS Service Man...		TO DO ▾	Unresolved

Threat Detection — Key Takeaways



Enable GuardDuty in ALL accounts and regions — it analyzes CloudTrail, VPC Flow Logs, and DNS logs with ML



AWS Security Hub is your CSPM — aggregate all findings centrally, track compliance scores across accounts



Amazon Inspector scans EC2, Lambda, and ECR continuously — prioritize findings by CVE severity and reachability



Amazon Detective helps answer 'How did this happen?' — graph-based investigation reduces MTTR significantly



Set up EventBridge rules to auto-respond to high-severity GuardDuty findings — automated containment saves critical minutes



Use MITRE ATT&CK framework to map GuardDuty findings to attack techniques — understand the full kill chain

07

Container & Kubernetes Security

Amazon EKS security at every layer

Container & Kubernetes Security

Amazon EKS security at every layer of the stack



User Request



Application Load Balancer



Amazon EKS Cluster



IRSA (Pod Identity)



AWS Services (S3, RDS, etc.)



Control Plane Security

- AWS-managed, auto-patched control plane
- Kubernetes RBAC + IAM integration
- Private API server endpoint option
- Envelope encryption for etcd secrets



Worker Node Security

- Use EKS Managed Node Groups
- IMDSv2 required (prevent SSRF)
- No SSH — use SSM Session Manager
- Dedicated node groups per workload



Network Policies

- Calico or VPC CNI network policies
- Default-deny all ingress + egress
- Allow only necessary pod-to-pod traffic
- Use namespaces for isolation

IRSA & Container Image Security

Fine-grained IAM permissions for pods + secure image pipeline

IAM Roles for Service Accounts (IRSA)

How it works:

1. Create IAM Role with trust policy for OIDC provider
2. Annotate Kubernetes Service Account with Role ARN
3. Pod assumes the IAM Role via projected token
4. AWS STS validates token and issues temp credentials
5. Pod accesses only permitted AWS services

✓ No node-level AWS credentials shared across all pods

Container Image Security

- | | |
|-----------------|---------------------------------|
| → Code Commit | Git + pre-commit hooks |
| → SAST Scan | Semgrep, Bandit |
| → Docker Build | Multi-stage builds |
| → Image Scan | ECR Scanning (Trivy), Inspector |
| → Sign & Push | Cosign, ECR (immutable tags) |
| → Deploy to EKS | OPA/Kyverno policy gate |

Runtime Security Tools

Falco:

Open-source K8s runtime security — detects anomalous container behavior

Amazon GuardDuty for EKS:

Analyzes EKS audit logs for suspicious activity (privilege escalation, unusual API calls)

OPA / Kyverno:

Policy as code — prevent privileged containers, enforce image registry allowlists

Container & Kubernetes Security — Key Takeaways

Secure every layer of your containerized workloads



Use IRSA (IAM Roles for Service Accounts) for pod-level IAM permissions — never use node-level instance profiles



Scan all container images with ECR Scanning and Inspector — scan on push AND continuously in registry



Implement Kubernetes Network Policies — default deny all ingress/egress, allow only necessary pod communication



Deploy Falco or GuardDuty for EKS for runtime threat detection inside running containers



Never run containers as root — use non-root user, read-only root filesystem, and drop all Linux capabilities



Use OPA or Kyverno to enforce pod security policies — reject privileged containers at admission time

08

DevSecOps & CI/CD Security

Security integrated into every pipeline stage

DevSecOps & Shift-Left Security

Integrating security into every stage of the development pipeline

💡 Shift Left: Find and fix vulnerabilities EARLIER in the pipeline — 100x cheaper to fix at code review than in production



Code

- SAST
- Secret Scanning
- Peer Review



Build

- Dep Scan
- License Check
- SBOM Gen



Test

- DAST
- Pen Testing
- IaC Scan



Package

- Container Scan
- Image Sign
- Registry Push



Deploy

- Policy Gate
- Config Check
- Drift Detect

IaC Security & Software Supply Chain

Securing your infrastructure templates and dependencies



Infrastructure as Code Security

Checkov

Scans Terraform, CloudFormation, Kubernetes manifests for misconfigs

cfn-nag

CloudFormation template linting for security anti-patterns

tfsec

Static analysis security scanner for Terraform code

AWS CDK nag

Security checks for AWS CDK applications



Supply Chain Security

SBOM

Software Bill of Materials — inventory of all components in your software

Sigstore / Cosign

Sign and verify container images and artifacts

Amazon CodeGuru

ML-based code review detecting security vulnerabilities

AWS CodeArtifact

Secure, private artifact repository with upstream caching

Secret Scanning & Dynamic Testing

Finding exposed secrets and runtime vulnerabilities before attackers do



Secret Scanning

Detecting hardcoded secrets before they hit production:

GitHub Advanced Security:

Push protection — blocks secrets from being committed

Gitleaks:

Scan git history for secrets — finds past mistakes

AWS Macie:

Find secrets and PII in S3 buckets using ML

truffleHog:

High-signal secret scanning with entropy analysis



Dynamic Application Security Testing

Test your running application for exploitable vulnerabilities:

OWASP ZAP:

Free automated web app scanner

Burp Suite:

Industry-standard web security testing

AWS Inspector:

Network reachability analysis on EC2

Penetration Testing:

AWS allows pentest on your own resources



Critical Reminder: NEVER commit secrets (passwords, API keys, tokens) to source control. If you do — assume it's compromised and rotate immediately.

DevSecOps — Key Takeaways

Security integrated, not bolted on



Shift Left: Fix vulnerabilities in code review (cost: \$1) vs in production (cost: \$100+)



Integrate SAST, secret scanning, and dependency scanning into every pull request — block PRs with critical findings



Build an SBOM for every release — know every dependency in your software supply chain



Sign all container images with Cosign — verify signatures before deploying to Kubernetes



Scan all IaC templates (Terraform, CloudFormation) with Checkov or cfn-nag before applying



Automate security — manual security gates are bottlenecks; automated checks are always on

09

Multi-Account Security Architecture

AWS Organizations & Landing Zone

AWS Organizations & Service Control Policies

Enforcing guardrails across every account in your organization

SCP Example: Deny Non-Approved Regions

Service Control Policies (SCPs)

SCPs set the maximum permissions boundaries for all accounts in an OU or the entire org. They CANNOT grant permissions — only restrict.

Common SCP Examples:

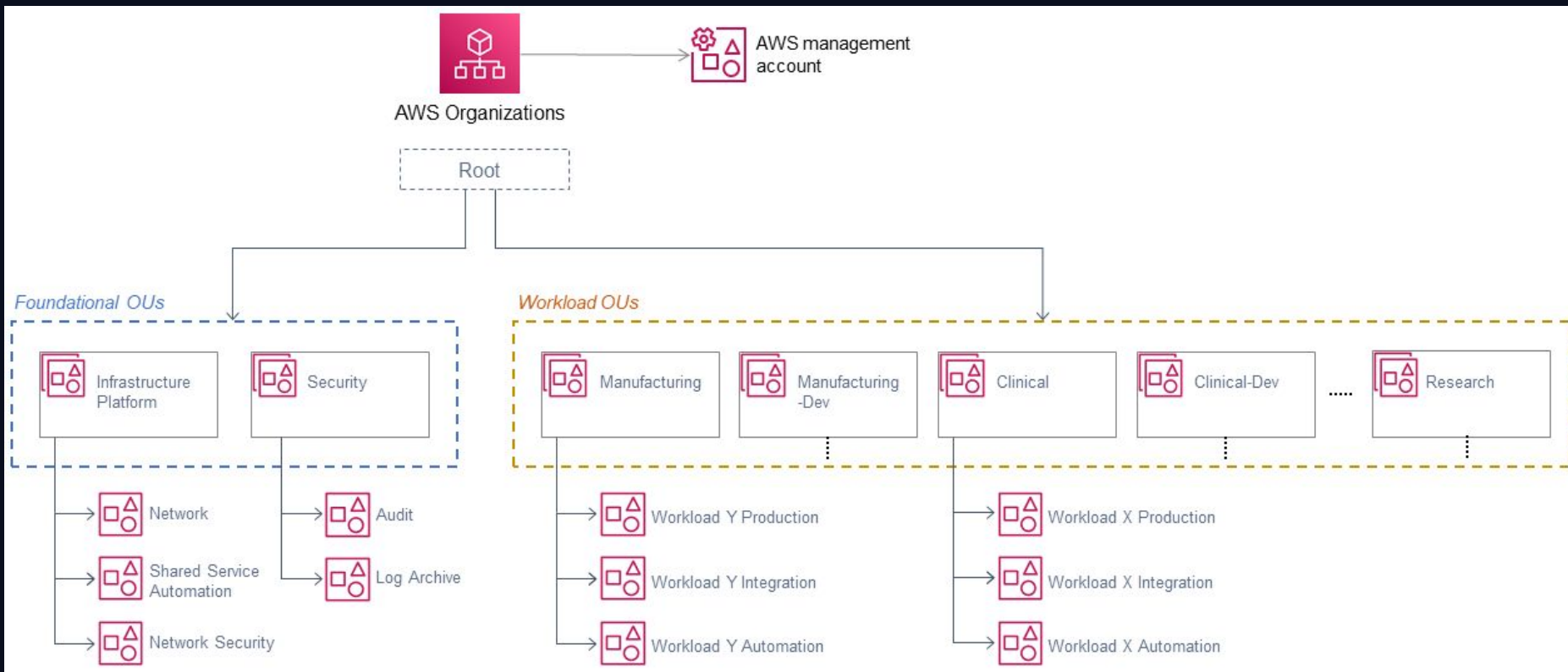
-  Prevent leaving AWS Organization
-  Require MFA to delete S3 buckets
-  Block services outside approved regions
-  Prevent disabling CloudTrail or GuardDuty
-  Enforce IMDSv2 on all EC2 instances
-  Deny creation of IAM users with console access

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "us-east-1",
            "ap-southeast-1"
          ]
        }
      }
    }
  ]
}
```

AWS Control Tower — Landing Zone

Automated multi-account setup with pre-configured SCPs, CloudTrail, Config, Security Hub, and IAM Identity Center

Multi-Account Security Architecture



Multi-Account — Key Takeaways

Structure your AWS organization for security at scale



Use AWS Organizations — single root, multiple accounts for workload isolation and blast radius control



Define SCPs at the OU level to enforce mandatory guardrails — no one can override them, not even root



Implement AWS Control Tower for an automated, compliant Landing Zone with pre-built security controls



Dedicate a Security Account for centralized GuardDuty, Security Hub, and Detective findings



Dedicate a Log Archive Account with immutable storage — even security admins shouldn't delete logs



Use IAM Identity Center for SSO across all accounts — single pane of glass for access management

010

Incident Response on AWS

Detect, Contain, Investigate, Recover, Learn

Incident Response on AWS

Detect → Contain → Investigate → Recover → Learn

1



Detection

GuardDuty alert, Security Hub finding, or CloudWatch alarm triggers the incident response process

2



Containment

Isolate the affected resource. Detach IAM policies, revoke access keys, quarantine EC2 in isolated SG

3



Investigation

Use CloudTrail, VPC Flow Logs, Amazon Detective to trace the attack path and determine blast radius

4



Recovery

Restore from clean backup, rotate all secrets, redeploy from IaC templates, verify integrity

5



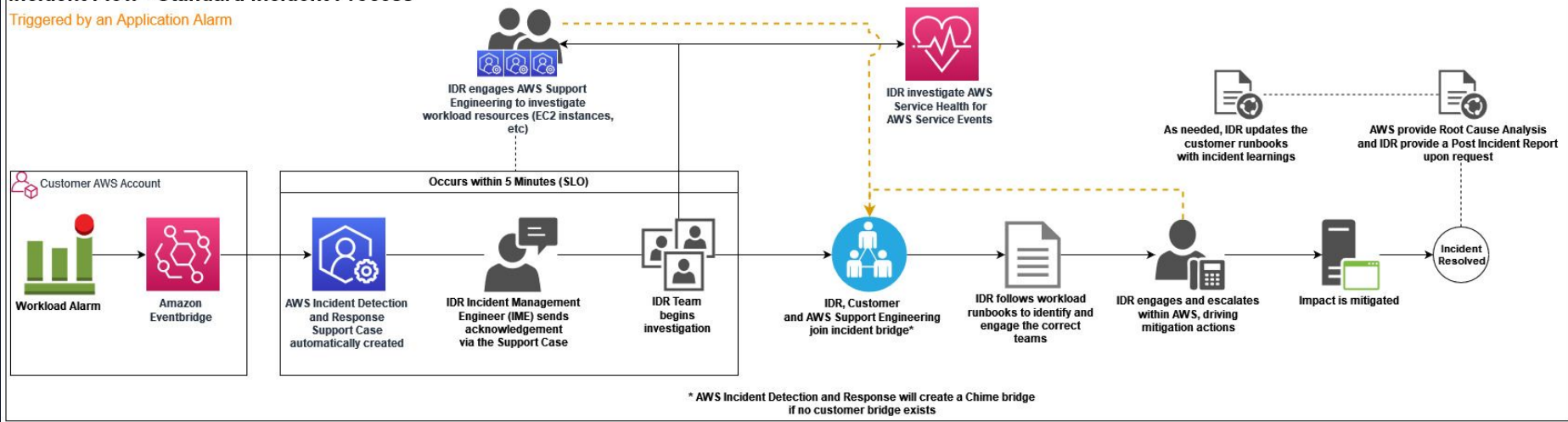
Lessons Learned

Post-mortem analysis, update runbooks, improve detection rules, train the team

Incident Response on AWS

Incident Flow - Standard Incident Process

Triggered by an Application Alarm



Zero Trust Architecture on AWS

Never trust, always verify — even inside the perimeter



Verify Explicitly

Authenticate and authorize every request based on all available data points: identity, location, device health, service, workload, data classification



Least Privilege Access

Limit user access with just-in-time and just-enough-access. Use risk-based adaptive policies and data protection.



Assume Breach

Minimize blast radius. Segment access. Encrypt end-to-end. Use analytics to drive threat detection and improve defenses.

AWS Zero Trust Building Blocks

Identity

IAM, Identity Center, Cognito

Device

AWS Systems Manager, GuardDuty

Network

VPC, PrivateLink, Network Firewall

Application

API Gateway + Authorizer, App Mesh

Data

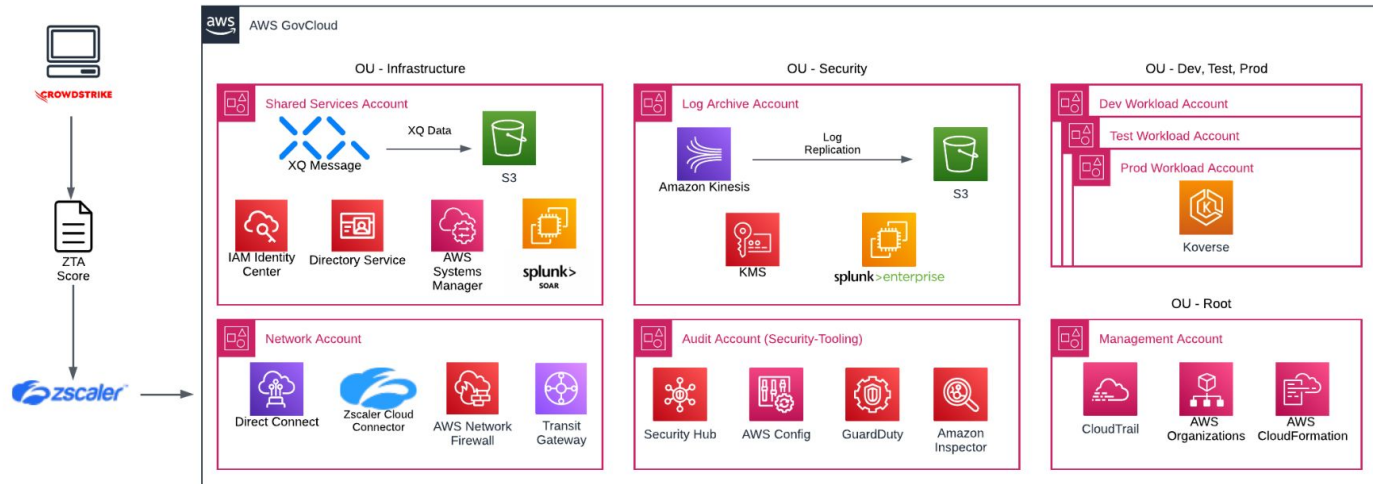
KMS, Macie, Lake Formation

Visibility

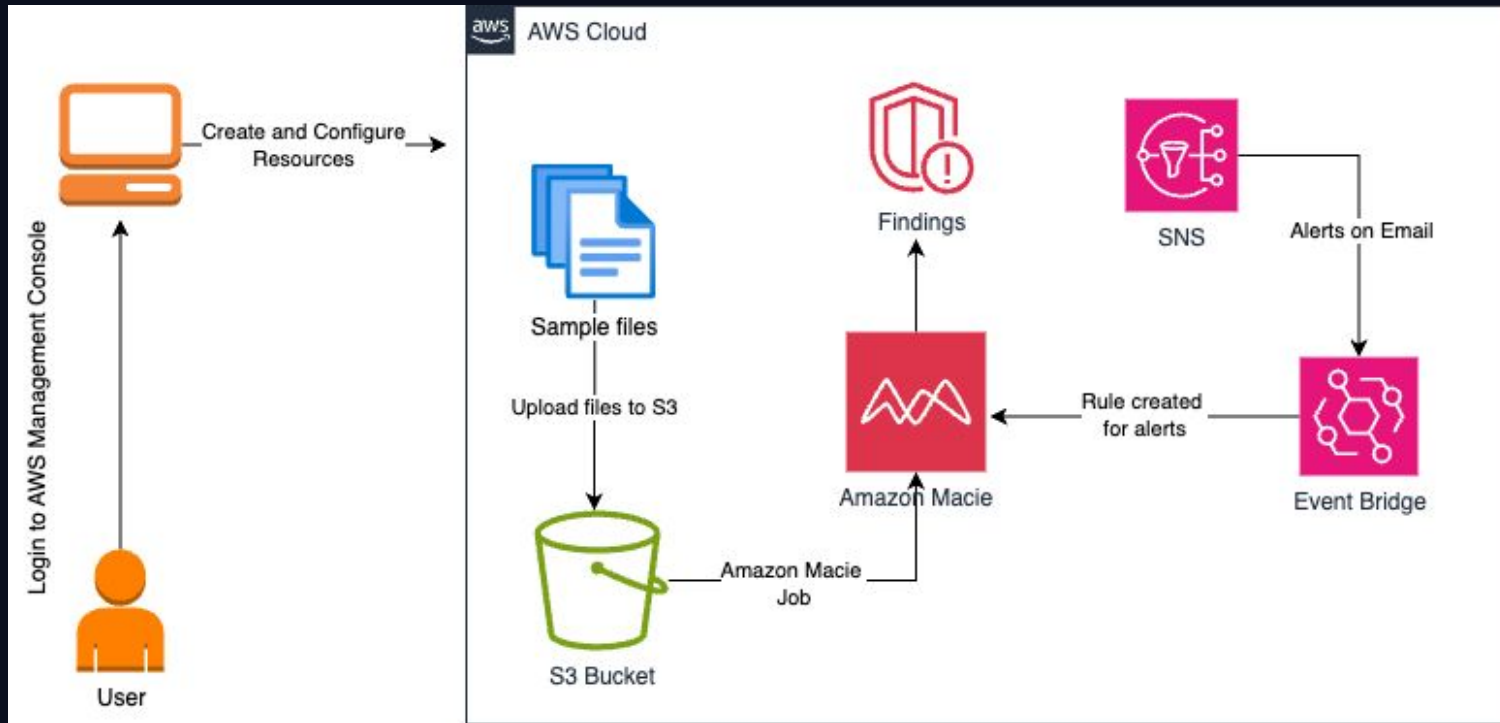
CloudTrail, Security Hub, Detective

Zero Trust Architecture on AWS

AWS Zero Trust Accelerator for Government - Integrated (ZTAG-I)



Hand-ons: Detect sensitive data in Amazon S3 buckets and send notifications using Amazon Macie



Thank You

AWS Security Architecture & Best Practices